SQL Injection Incident Report

Target: `shop.meridianretail.com`
Source log: `/africahackon-course/AH-Scripting-Practicals/Bash_Scripting/01_Log_Analysis/logs/01_sql_injection_meridian_retail.log`
Generated: 2026-10-31 11:24:43 UTC
Producer: `sqli_incident_analysis.sh` (automated Bash analysis)

Severity: CRITICAL - Exploit succeeded - credentials stolen, login bypassed, data exfiltrated

Executive summary

The access log for `shop.meridianretail.com` covers 2499 requests from 157 client IPs; 1026 rows (41%) carry attack indicators, from 7 distinct addresses:

- Automated tooling (`acunetixscanner sqlmap/1.7.2#stable`) scanned the application over 137 requests. 980 requests carried injection payloads across 2 endpoint/parameter pairs.
- 840 blind boolean probes over 1.8 h pulled column values out one character at a time. UNION queries paged out 5 tables (admin_sessions, employee_payroll_view, gift_cards, saved_payment_methods, users).
- The login form was bypassed with an injected username from 185.220.101.47, yielding session `sess_9f2c1a`. 61.3 MB then left through that session in 18 bulk export/backup requests. 6 customer accounts were taken over with the harvested credentials and 6 fraudulent orders were placed.

Metric	Value
Log lines / requests	2500 / 2499
Time range	14/Jul/2026:00:01:32 to 15/Jul/2026:22:49:59
Rows with attack indicators	1026 (41%)
Attacker IPs	7
SQLi-carrying requests	980
Tables dumped	5
Blind probes	840
Auth bypass / accounts taken over	1 / 6
Data exfiltrated	61.3 MB in 18 requests
WAF blocks / SOC alerts	2 / 1

Attack timeline

Stage	Events	First seen	Last seen	Acto
Automated scanning / at..	137	14/Jul/2026:..	15/Jul/2026:..	2
Boolean-based SQLi payl..	22	14/Jul/2026:..	15/Jul/2026:..	2
Time-based (SLEEP) prob..	30	14/Jul/2026:..	15/Jul/2026:..	2
Schema / DB metadata en..	13	15/Jul/2026:..	15/Jul/2026:..	1
UNION-based data extrac..	83	14/Jul/2026:..	15/Jul/2026:..	2

Stage	Events	First seen	Last seen	Acto
Stacked / destructive s..	2	15/Jul/2026:..	15/Jul/2026:..	1
Blind boolean extractio..	840	14/Jul/2026:..	14/Jul/2026:..	1
Authentication bypass	1	15/Jul/2026:..	15/Jul/2026:..	1
Admin-area requests	20	15/Jul/2026:..	15/Jul/2026:..	1
Bulk data exfiltration	18	15/Jul/2026:..	15/Jul/2026:..	1
Rejected logins (stuffi..	12	15/Jul/2026:..	15/Jul/2026:..	3
Successful account take..	6	15/Jul/2026:..	15/Jul/2026:..	3
Fraudulent orders	6	15/Jul/2026:..	15/Jul/2026:..	3
WAF blocks	2	15/Jul/2026:..	15/Jul/2026:..	1
SOC / WAF alerts	1	15/Jul/2026:..	15/Jul/2026:..	0

1. Attack surface

Every endpoint/parameter pair that carried an injection payload:

Endpoint	Parameter	Requests
/product/detail	id	947
/search	q	33

2. Automated tooling

Requests	User-Agent
80	Mozilla/5.0 (compatible; AcunetixScanner)
57	sqlmap/1.7.2#stable (http://sqlmap.org)

3. SQL injection payload classes

Class	Requests	Distinct IPs
Boolean-based SQLi payloads	22	2
Time-based (SLEEP) probing	30	2
Schema / DB metadata enumeration	13	1
UNION-based data extraction	83	2
Stacked / destructive statements	2	1
Blind boolean extraction campa..	840	1

4. Blind boolean-based extraction

Field	Value
Probes	840
Rate	0.13 probes/s over 1.8 h
Confirmed character matches	168
Mean response time	0.19s
Source IPs	91.132.45.201 (840)
Data targeted	admin_accounts.password_hash (640 probes) admin_accounts.ap..

The attacker asked the database yes/no questions - "is character N of the admin password hash greater than 55?", "does it equal 0x62?" - and inferred the answer from the response

shape rather than from any error. Roughly 840 probes decoded a credential column a character at a time. This is the quietest stage in the log: every request returned 200 with a plausible response size.

5. UNION-based dumps

83 UNION requests; schema objects probed: `information_schema.columns` `information_schema.tables`; paging: 40 dump pages of 50 rows (offsets 0..350).

Table	Dump requests	Columns exfiltrated
admin_sessions	8	session_token,user_..
employee_payroll_view	8	employee_name,salar..
gift_cards	8	card_code,balance,i..
saved_payment_methods	8	card_number,card_ex..
users	8	username,password,e..

The attacker first sent `UNION SELECT NULL` probes to count columns, then replaced each `NULL` with a column of interest and paged through the table 50 rows at a time. Column-count probing is the signature to alert on: a normal customer never sends `UNION SELECT` anywhere near a product page.

6. Authentication bypass

Field	Value
Timestamp	15/Jul/2026:01:25:27
Source IP	185.220.101.47
Client	curl/8.4.0
Injected login	username=admin'-- -&password=anything
Password field	never evaluated - commented out by the payload
Session granted	sess_9f2c1a
Redirect	/admin/dashboard

The login query was built by string concatenation, so the username payload closed the literal and commented out the password comparison. The application answered 302 to the admin dashboard: from its point of view, an administrator had logged in.

7. Post-bypass admin activity

20 requests carried the hijacked session `sess_9f2c1a`:

Requests	Path
2	/admin/export_customers
1	/admin/users/export
1	/admin/orders/export
1	/admin/export/saved_payment_methods
1	/admin/export/gift_cards
1	/admin/export/employee_payroll_view
1	/admin/export/admin_sessions
1	/admin/dashboard
1	/admin/customers

Requests	Path
1	/admin/backups/customer_data_part9.csv.gz
1	/admin/backups/customer_data_part8.csv.gz
1	/admin/backups/customer_data_part7.csv.gz
1	/admin/backups/customer_data_part6.csv.gz
1	/admin/backups/customer_data_part5.csv.gz
1	/admin/backups/customer_data_part4.csv.gz
1	/admin/backups/customer_data_part3.csv.gz
1	/admin/backups/customer_data_part2.csv.gz
1	/admin/backups/customer_data_part10.csv.gz
1	/admin/backups/customer_data_part1.csv.gz

8. Data exfiltration

61.3 MB (64307891 bytes) left the network in 18 requests.

Size	Path
9.18 MB	/admin/export_customers?format=csv&range=all
5.82 MB	/admin/orders/export?format=csv
4.90 MB	/admin/backups/customer_data_part8.csv.gz
4.85 MB	/admin/backups/customer_data_part5.csv.gz
4.59 MB	/admin/export_customers?format=csv
4.50 MB	/admin/backups/customer_data_part6.csv.gz
3.39 MB	/admin/backups/customer_data_part4.csv.gz
3.20 MB	/admin/export/saved_payment_methods?format=csv
3.11 MB	/admin/backups/customer_data_part10.csv.gz
2.93 MB	/admin/backups/customer_data_part1.csv.gz
2.44 MB	/admin/backups/customer_data_part7.csv.gz
2.41 MB	/admin/backups/customer_data_part9.csv.gz
2.14 MB	/admin/export/employee_payroll_view?format=csv
2.11 MB	/admin/users/export?format=csv
2.01 MB	/admin/backups/customer_data_part3.csv.gz
1.77 MB	/admin/backups/customer_data_part2.csv.gz
1.15 MB	/admin/export/gift_cards?format=csv
0.84 MB	/admin/export/admin_sessions?format=csv

Every transfer is a complete export or a numbered backup chunk: this was a copy, not a browse. Treat all of these data sets as breached.

9. Credential stuffing and account takeover

Metric	Value
Login POSTs	73
Rejected	12
Succeeded (ATO)	6
Stuffing IPs	3
Clusters	45.134.26.0/24
Client	python-requests/2.31.0

IP	Attempts	Succeeded
45.134.26.88	9	2
45.134.26.103	5	3
185.220.101.47	5	0
45.134.26.91	4	1
196.122.179.171	3	0
79.24.179.217	2	0
46.133.108.212	2	0
45.77.64.204	2	0

Compromised customer accounts (6):

- ann.wanjiru556@gmail.com
- brian.wafula56@proton.me
- diana.akinyi887@outlook.com
- ibrahim.odhiambo511@proton.me
- robert.mohamed207@yahoo.com
- simon.maina220@yahoo.com

Fraudulent orders (6):

Time	Account	Phone
15/Jul/2026:09:03:44	diana.akinyi887@outlook.com	+254-713-495-373
15/Jul/2026:09:12:02	simon.maina220@yahoo.com	+44-7844-963468
15/Jul/2026:09:13:35	ibrahim.odhiambo511@proton.me	+254-767-695-444
15/Jul/2026:09:14:11	robert.mohamed207@yahoo.com	+254-737-153-533
15/Jul/2026:09:17:26	ann.wanjiru556@gmail.com	+254-776-355-745
15/Jul/2026:09:18:20	brian.wafula56@proton.me	+254-722-532-574

10. Detection controls

Control	Events	Detail
WAF blocks	2	2 x rule=stacked_queries;
SOC alerts	1	"Multiple SQLi campaigns detected ..

The WAF only stopped stacked DROP/UPDATE statements. UNION dumps, blind inference and the login bypass passed straight through, so the block list bought less time than it looked like it did. Coverage has to follow the payload families actually in use, not just the loudest one.

11. Indicators of compromise

Type	Value
Attacking IPs	91.132.45.201 185.220.102.8 185.220.101.47 185.220.101.52 45..
Hijacked session	sess_9f2c1a
Tooling signatures	acunetixscanner sqlmap/1.7.2#stable
Injection points	/product/detail?id /search?q
Dumped tables	admin_sessions employee_payroll_view gift_cards saved_paymen..
Compromised accounts	ann.wanjiru556@gmail.com brian.wafula56@proton.me diana.akin..

Type	Value
Exfil endpoints	/admin/export_customers?format=csv&range=all /admin/orders/e..

12. Root cause and remediation

Root cause. User input reached SQL string concatenation on two surfaces: the read path (`/product/detail?id=` and `/search?q=`) and the authentication path (`/account/login`). Because the query text changed with attacker input, one injection point cascaded into schema enumeration, credential theft and a full login bypass (OWASP Top 10 A03:2021 - Injection). The exported backups and payroll data show the database account also had far more read access than a storefront needs.

Priority	Action
P0	Revoke session sess_9f2c1a, rotate all admin credentials, fo..
P0	Treat the 5 dumped tables as breached: regulator and card-ne..
P1	Replace every string-built query with parameterized statemen..
P1	Give the web application a least-privilege database account:..
P1	Add MFA and rate limiting to login plus breached-password de..
P2	Extend WAF rules to UNION, blind inference and auth-bypass p..
P2	Block the attacker IPs and alert on sqlmap/Acunetix user age..
P2	Require re-authentication for /admin/ and treat bulk export/..